

מודול 16 — כתיבת דוח ותיעוד — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 16: כתיבת דוח ותיעוד

2.  פתרונות ודוגמאות — מודול 16: כתיבת דוח ותיעוד

תרגילים — מודול 16: כתיבת דוח ותיעוד

תרגילים אלה מתמקדים ב**כתיבה** — קח ממצאים מהמודולים הקודמים והפוך אותם לדוח מקצועי. פתרונות ודוגמאות ב- [solutions.md](#).

מקרא רמות:  קל ·  בינוני ·  מתקדם ·  אתגר

חלק א' — יסודות ()

16.1 — הסבר במילים שלך למה “הדוח הוא המוצר”. מה קורה לבדיקה מבריקה עם דוח גרוע?

16.2 — מהם RoE ו-Scope, ולמה חובה להגדיר אותם ב**כתב לפני** הבדיקה?

16.3 — רשום את ששת חלקי הדוח הסטנדרטי לפי הסדר.

חלק ב' — כתיבה ()

16.4 — כתוב **Executive Summary** (פסקה) לתרחיש: נמצאה SQLi בדף לקוחות שחושפת את כל מסד הנתונים. **בשפה עסקית, ללא ז'רגון טכני.**

16.5 — קח ממצא ממודול קודם (למשל IDOR ממודול 9, או Kerberoast ממודול 13) וכתוב אותו במבנה ממצא מלא: תיאור, השפעה, PoC, תיקון, הפניות.

16.6 — דרג שלושה ממצאים ב-CVSS: (א) SQLi בדף לקוחות ציבורי; (ב) גרסת שרת חשופה ב-banner; (ג) סיסמת admin חלשה. נמק כל דירוג.

חלק ג' — מקצועיות ()

16.7 — כתוב **המלצות תיקון** לשלושת הממצאים מ-16.6 — ספציפיות, ישימות, ומדורגות לפי עדיפות.

16.8 — הסבר איך היית מתעד ממצא **בזמן אמת** בזמן בדיקה. אילו כלים תשתמש, ולמה לא לחכות לסוף?

16.9 — נסח **טבלת סיכום ממצאים** (Finding | Severity | Status) עבור בדיקה עם 5 ממצאים לדוגמה.

אתגר מסכם — “דוח בדיקת חדירה מלא”

הרכב דוח בדיקת חדירה שלם על בסיס אחד מהאתגרים שביצעת בקורס (מודול 9 web, מודול 11 privesc, או מודול 13 AD):

1. שער — לקוח (פיקטיבי), תאריכים, סיווג.
2. Executive Summary — תמונת מצב + סיכון עסקי + 3 המלצות מפתח.
3. היקף ומתודולוגיה — מה נבדק ואיך.
4. טבלת סיכום ממצאים — כל הממצאים + חומרה.
5. ממצאים מפורטים — לפחות 3 ממצאים במבנה מלא (עם PoC וצילומים).
6. נספח — פלטים/פקודות.

זהו תוצר הגמר של הקורס — דוח בדיקת חדירה אמיתי. הוא המסמך שתציג בראיון עבודה, ובדיוק מה שנדרש בבחינת PNPT. שמור אותו כפורטפוליו.

רשימת בקרה — סיום הקורס

- ☐ אני מבין שהדוח הוא המוצר ומקדיש לו זמן
- ☐ אני מגדיר Scope/RoE לפני בדיקה
- ☐ אני כותב Executive Summary בשפה עסקית
- ☐ אני כותב ממצא מלא עם PoC ותיקון
- ☐ אני מדרג חומרה עם CVSS לפי סיכון עסקי
- ☐ אני כותב המלצות תיקון ספציפיות וישימות
- ☐ אני מתעד בזמן אמת עם כלים מתאימים
- ☐ הרכבתי דוח בדיקת חדירה מלא לפורטפוליו

פתרונות ודוגמאות: [solutions.md](#)

פתרונות ודוגמאות — מודול 16: כתיבת דוח ותיעוד

נסה לבד ב- [missions.md](#) קודם. אלו דוגמאות ייחוס — הסגנון שלך יכול להשתנות.

חלק א' — יסודות

16.1 — הלקוח לא רואה את הפריצה, רק את הדוח; הדוח מתרגם ממצאים לערך (סיכון, תיקון, ציות). בדיקה מבריקה עם דוח גרוע = הלקוח לא מבין ולא מתקן → כישלון מקצועי.

16.2 — **Scope** = מה מותר לבדוק (טווחי IP, דומיינים, אפליקציות); **RoE** = איך ומתי (חלונות זמן, מגבלות, אנשי קשר). חובה בכתב מראש כי בלעדיהם אתה **חשוף משפטי** ועלול לפגוע במערכות מחוץ להיקף.

16.3 — (1 שער ופרטים; 2 Executive Summary; 3 היקף ומתודולוגיה; 4 סיכום ממצאים; 5 ממצאים מפורטים; 6 נספחים).

חלק ב' — כתיבה

16.4 (דוגמה) < במהלך הבדיקה זוהתה חולשה קריטית באתר הלקוחות המאפשרת לתוקף בלתי-מורשה לגשת ל**כל מסד נתוני הלקוחות**, כולל שמות, כתובות ופרטי אשראי. ניצול החולשה אינו דורש הרשאות מוקדמות. הסיכון כולל **חשיפת מידע רגיש, קנסות רגולטוריים (GDPR/PCI) ופגיעה במוניטין**. מומלץ לתקן באופן מיידי.

16.5 (דוגמה — IDOR)

High (CVSS 7.5) :חומרה — (IDOR) גישה לא-מורשית לחשבונות לקוחות

id ניתן לשנות את הפרמטר /account?id=1001 תיאור: ** בכתובת: **
ולגשת לנתוני לקוחות אחרים ללא בדיקת בעלות.

השפעה: ** תוקף מאומת יכול לצפות בנתונים אישיים של כל הלקוחות: **
(דליפת מידע המונית).

****PoC:****

1. (החשבון שלך) /account?id=1001 -התחבר כמשתמש רגיל, גש ל.
2. מוצגים נתוני לקוח אחר. [צילום] → /account?id=1002 -שנה ל.

תיקון: ** אכוף בדיקת הרשאה בצד השרת — ודא שהממשאב שייך: **
למשתמש המחובר בכל בקשה.

****הפניות:**** OWASP A01:2021, CWE-639.

16.6 - (א) SQLi בדף לקוחות ציבורי → **Critical (9.8)** — נגיש מרחוק, ללא אימות, חשיפת נתונים מלאה. -
(ב) Banner חושף גרסה → **Low/Info (3.1)** — מידע בלבד, לא ניצול ישיר. - (ג) סיסמת admin חלשה →
High (8.1) — מובילה להשתלטות, אך דורשת הגעה לממשק.

חלק ג' — מקצועיות

16.7 - SQLi (Critical): תקן מיד — עבור ל-Prepared Statements/ORB בכל השאילות; WAF כאמצעי ביניים. - **סיסמת (High) admin:** אכוף מדיניות סיסמאות חזקה + MFA; החלף סיסמאות קיימות. - **Banner (Low):** הסתר גרסאות ב-headers; עדיפות נמוכה, לטיפול בתחזוקה שוטפת.

16.8 — מתעדים בזמן אמת: צילום מסך לכל ממצא (Flameshot), לוג פקודות (tmux/ script), ומחברת (CherryTree/Obsidian). לא מחכים לסוף כי הפרטים נשכחים, סביבות משתנות, ואי אפשר לשחזר PoC ממכונה שאופסה.

16.9 (דוגמה)

```
| # | ממצא | חומרה | סטטוס | |
|---|---|---|---|---|
| 1 | SQL Injection | בדרך התחברות | Critical | פתוח |
| 2 | Kerberoastable service account | High | פתוח |
| 3 | IDOR | בפרופיל לקוח | High | פתוח |
| 4 | סיסמאות חלשות (3 חשבונות) | Medium | פתוח |
| 5 | banner-חשופה ב Apache | Low | פתוח | גרסת
```

אתגר מסכם — שלד דוח מלא

```
# <דוח בדיקת חדירה - >לקוח [CONFIDENTIAL]
__ :תאריכים: __ | גרסה: 1.0 | בודק

## 1. Executive Summary
המאפשר השתלטות מלאה SQLi :החמור. (קריטיים X) ממצאים N נמצאו
על מסד הלקוחות. סיכון עסקי: חשיפת מידע + קנס רגולטורי
.הדרכות (3) MFA מיד; (2) אכוף SQLi המלצות מפתח: (1) תקן 3

## 2. היקף ומתודולוגיה
__ :חלון. PTES/OWASP :שיטה. app.client.com :נבדק

## 3. סיכום ממצאים
[טבלה - ראה 16.9]

## 4. ממצאים מפורטים
[ממצאים במבנה מלא - ראה 16.5 +3]

## 5. נספחים
.פקודות, רשימת מכונות, nmap פלטי
```

